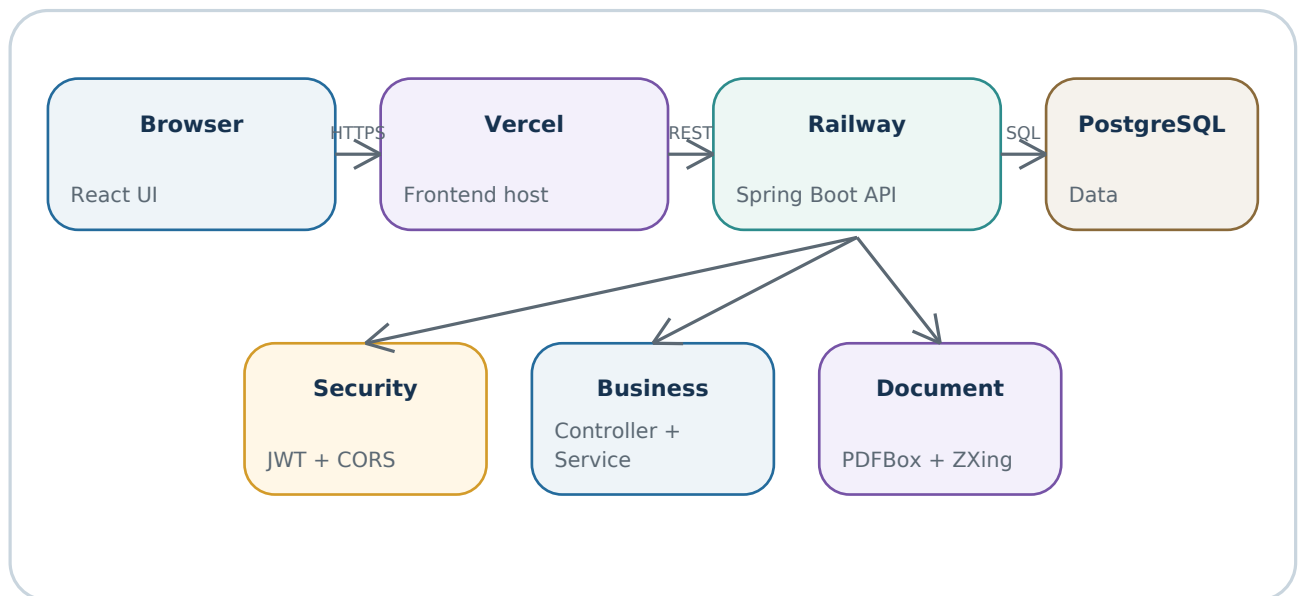


HAL Smart PDF Approval & QR Verification System

Interview Master Guide • Full Answers • Visual Drawings • Follow-ups • Troubleshooting



How to use this guide

Read the diagrams first. Then follow each arrow as a request travels through the system. For every component ask: What is it? Why is it here? What calls it? What can fail?

How to use this interview guide

Use a three-pass method: Pass 1 — speak the short answer; Pass 2 — read the full answer; Pass 3 — draw the figure and explain the request flow. The goal is not to sound memorized. The goal is to demonstrate ownership of the design decisions.

Answer formula

For most project questions: What → Why → How in my project → trade-off/failure case.

Interview roadmap

01. Project ownership

Q1-Q8

02. Spring Boot

Q9-Q20

03. Security + JWT

Q21-Q31

04. JPA + PostgreSQL

Q32-Q41

05. PDF + QR

Q42-Q48

06. Frontend + API

Q49-Q55

07. Docker + deployment

Q56-Q61

08. Debugging + scenarios

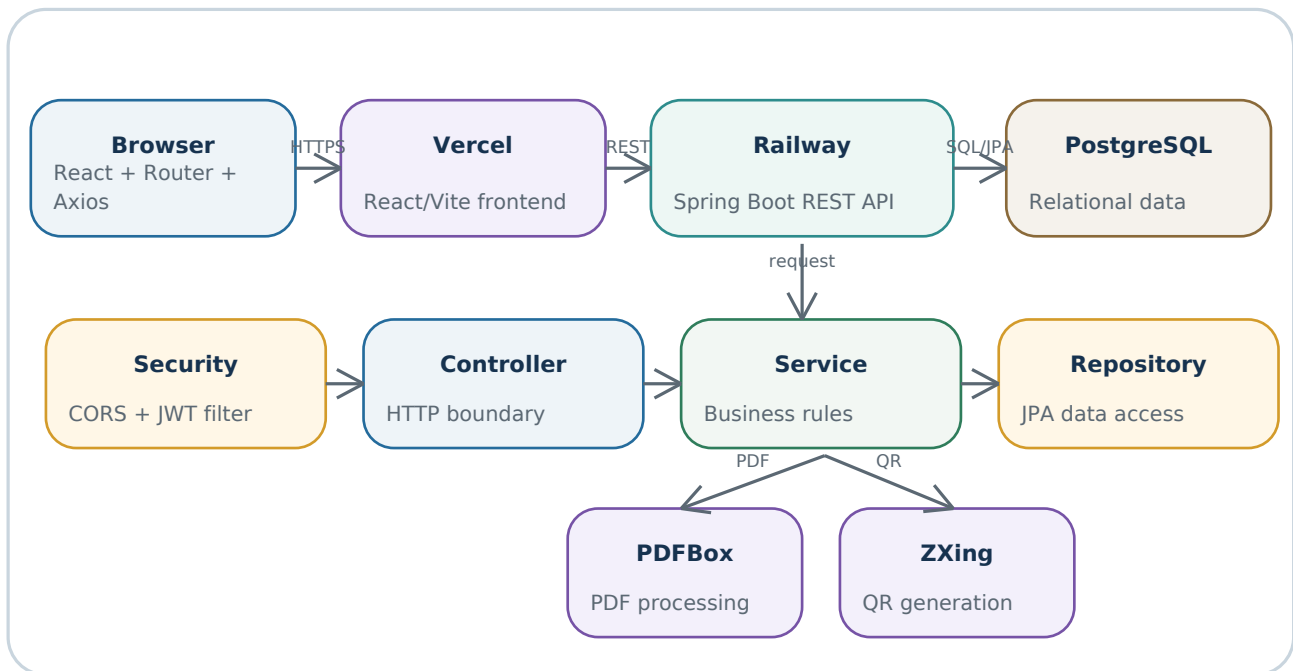
Q62-Q70

01 — Project ownership & architecture

01 Tell me about your project.

PROJECT

I built a full-stack document approval and QR verification system. The React/Vite frontend communicates with a Spring Boot REST backend. Employees authenticate using JWT and BCrypt, upload PDFs, and administrators review and approve or reject them. On approval, the backend uses PDFBox for PDF processing and ZXing for QR generation. PostgreSQL stores employees, roles, departments and document metadata. I use Docker Compose locally and Vercel/Railway for production.



02 Why did you choose this project?

PROJECT

It represents a realistic enterprise workflow: controlled access, document state transitions, approval authority, traceability and verification. It also forced me to understand full-stack integration rather than building an isolated CRUD screen.

03 What exactly did you implement?

OWNERSHIP

I can explain and defend the React routing/UI, REST APIs, Spring Boot service design, JPA/PostgreSQL integration, JWT/BCrypt security, PDF/QR workflow, Docker setup, Git integration, deployment and production debugging. I avoid claiming features I did not actually implement.

04 What was the hardest part?

DEBUGGING

Production debugging was the hardest because the local environment worked while deployment introduced new failure modes. A live login failure was traced through Railway logs to a missing employee relation; after schema initialization, JWT generation exposed an empty JWT secret. The important lesson was to use evidence from logs and the Network tab rather than changing code randomly.

05 Explain the architecture in one minute.

ARCHITECTURE

The browser runs the React/Vite client. Vercel serves the production frontend. Axios sends HTTPS REST requests to the Spring Boot backend on Railway. Spring Security authenticates JWTs, controllers handle HTTP, services apply business rules, repositories/JPA access PostgreSQL, and PDFBox/ZXing handle approved-document processing.

06 Why Controller-Service-Repository?

SPRING

It separates HTTP concerns, business logic and persistence. Controllers stay thin, services remain reusable and testable, and repositories isolate database operations. It also makes the system easier to change because an HTTP endpoint does not need to know how the database is queried.

07 What is dependency injection and where do you use it?

SPRING

Dependency injection means a class receives the objects it depends on instead of constructing them itself. Spring creates and wires beans through its IoC container. In this project, controllers receive services, services receive repositories or infrastructure components, and the security configuration wires the JWT filter and password encoder.

08 What happens when a protected HTTP request enters Spring Boot?

SPRING

The request reaches the embedded server, enters the Spring Security filter chain, and the JWT authentication filter can extract the Bearer token and validate it. If authentication succeeds, Spring Security establishes the authenticated principal. Spring MVC then maps the request to a controller, which delegates to the service and eventually the repository if persistence is needed.

02 — Spring Boot & web fundamentals

09 What is Spring Boot actually giving you?

SPRING

Spring Boot provides conventions, auto-configuration, embedded server support, dependency management and an application model built around Spring's IoC container. It reduces setup so I can focus on the application rather than manually configuring every infrastructure component.

10 What is IoC?

SPRING

Inversion of Control means object creation and lifecycle are controlled by the framework rather than by application classes directly. Instead of writing new Service() inside a controller, I declare the dependency and Spring supplies the bean.

11 What is a Spring Bean?

SPRING

A bean is an object managed by the Spring container. Spring creates it, configures it, injects dependencies and manages its lifecycle according to its scope and configuration.

12 @RestController vs @Controller?

WEB

@RestController is effectively @Controller plus response-body semantics, so returned values are written as HTTP response data, commonly JSON. A traditional @Controller is typically used for MVC view rendering unless methods explicitly use @ResponseBody.

13 @RequestMapping, @GetMapping, @PostMapping?

WEB

RequestMapping provides general request mapping. The composed annotations such as GetMapping and PostMapping express the HTTP method directly and make endpoint intent clearer.

14 @PathVariable vs @RequestParam?

WEB

PathVariable extracts a value from the URL path, such as /documents/{id}. RequestParam extracts a query parameter, such as /documents?status=PENDING. I use path variables for resource identity and query parameters for filtering/options.

15 What is @RequestBody?

WEB

It tells Spring MVC to deserialize the request body into a Java object, commonly a DTO. With JSON requests, Jackson performs the JSON-to-object conversion.

16 Why use DTOs?

DESIGN

DTOs keep the HTTP contract separate from persistence entities. This avoids exposing internal fields such as password hashes and makes API payloads easier to validate and evolve.

17 What does @Transactional do?

JPA

It defines a transaction boundary so a group of database operations can commit together or roll back on failure according to transaction rules. In an approval workflow, transactions help keep document state and related database changes consistent.

18 What is the difference between authentication and authorization?

SECURITY

Authentication answers “Who are you?” Authorization answers “What are you allowed to do?” In this project, JWT helps authenticate the caller; role/action checks determine whether that authenticated caller can perform administrative operations.

19 Why should controllers be thin?

DESIGN

A controller should translate HTTP input into a call to the business layer and translate the result back into an HTTP response. If it contains database logic, file processing and authorization rules, responsibilities become mixed and testing becomes harder.

20 What is CORS and why did you need it?

SECURITY

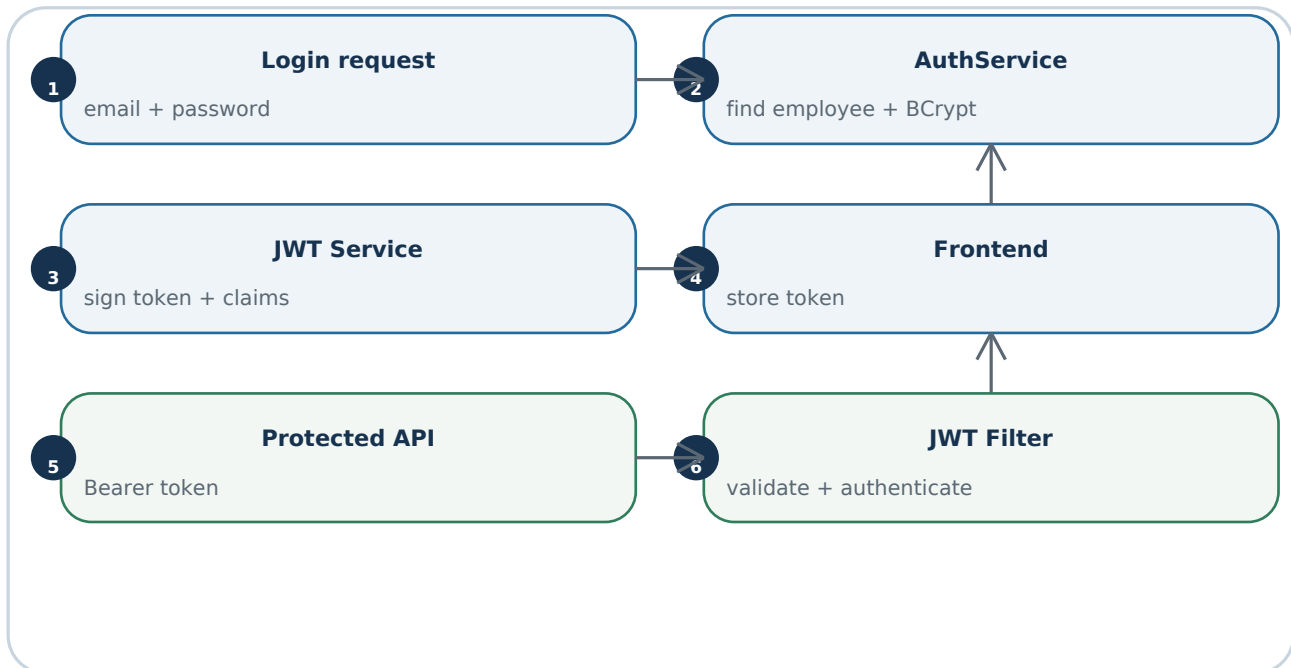
CORS is a browser security mechanism controlling which origins may make cross-origin requests. Because the Vercel frontend and Railway API have different origins, the backend must allow the actual frontend origin through its CORS configuration.

03 — Security & JWT

21 Explain the JWT login flow.

SECURITY

The client sends credentials to the login endpoint. The AuthService finds the employee by email and verifies the submitted password against the BCrypt hash. If valid, the JWT service signs a token containing the necessary identity/claims and an expiration. The frontend stores the token and sends it as a Bearer token on protected API calls.



22 Why JWT instead of server-side sessions?

SECURITY

JWT can support stateless API authentication because the server can validate the signed token without keeping a session object for every request. The trade-off is token revocation is more complex, so expiration, secure storage and refresh/revocation strategies matter in production.

23 Why BCrypt?

SECURITY

Passwords should not be encrypted for later recovery; they should be stored as one-way password hashes. BCrypt includes a salt and configurable work factor, making offline password guessing more expensive.

24 What happens if JWT_SECRET is empty?

DEBUGGING

The signing operation can fail because the cryptographic key is invalid or too weak. In the deployed system this appeared as a JJWT WeakKeyException. The fix is to supply a strong non-empty secret through the deployment environment rather than hard-code it.

25 Where should JWT_SECRET be stored?

SECURITY

As a deployment secret/environment variable or secret-management system. It should not be committed to GitHub or placed in frontend code because the signing secret must remain server-side.

26 Why is localStorage token checking not enough?

SECURITY

The browser is controlled by the user. They can alter localStorage or bypass the UI completely and call the API with another client. Therefore localStorage checks can improve navigation UX but cannot enforce authorization. The server must validate the token and permissions.

27 What does a JWT filter do?

SECURITY

It inspects incoming requests for a Bearer token, validates its signature and claims, and if valid creates the authenticated security context so downstream authorization can use the authenticated identity.

28 What is stateless authentication?

SECURITY

The server does not keep a login session object as the source of truth for each client. Each request carries enough signed information for the server to validate the caller. JWT is a common mechanism for this.

29 What is authorization in your project?

SECURITY

It is the rule layer that determines which authenticated users may access endpoints or perform operations. For example, administrative approval should not be available merely because a user has a valid JWT.

30 How would you improve the security of this project?

FOLLOW-UP

I would consider HttpOnly secure cookies or a carefully designed token strategy, refresh-token rotation, stronger role/permission modeling, audit logs, input validation, rate limiting, centralized error handling, malware/file validation, durable object storage, and secret management.

31 How would you handle logout with JWT?

FOLLOW-UP

A simple client-side logout removes the token. For stronger revocation requirements, I would introduce short-lived access tokens with refresh-token rotation and server-side revocation/blacklisting where necessary.

04 — JPA & PostgreSQL

32 What is JPA?

DATABASE

JPA is a Java persistence specification for mapping Java objects to relational data. Hibernate is the JPA implementation used commonly with Spring Boot. It lets the application work with entities and repositories while the ORM generates SQL for many operations.

33 What is Hibernate?

DATABASE

Hibernate is an ORM framework and a common JPA provider. It maps entities to tables, tracks persistent state and generates SQL based on entity operations and queries.

34 Why use PostgreSQL?

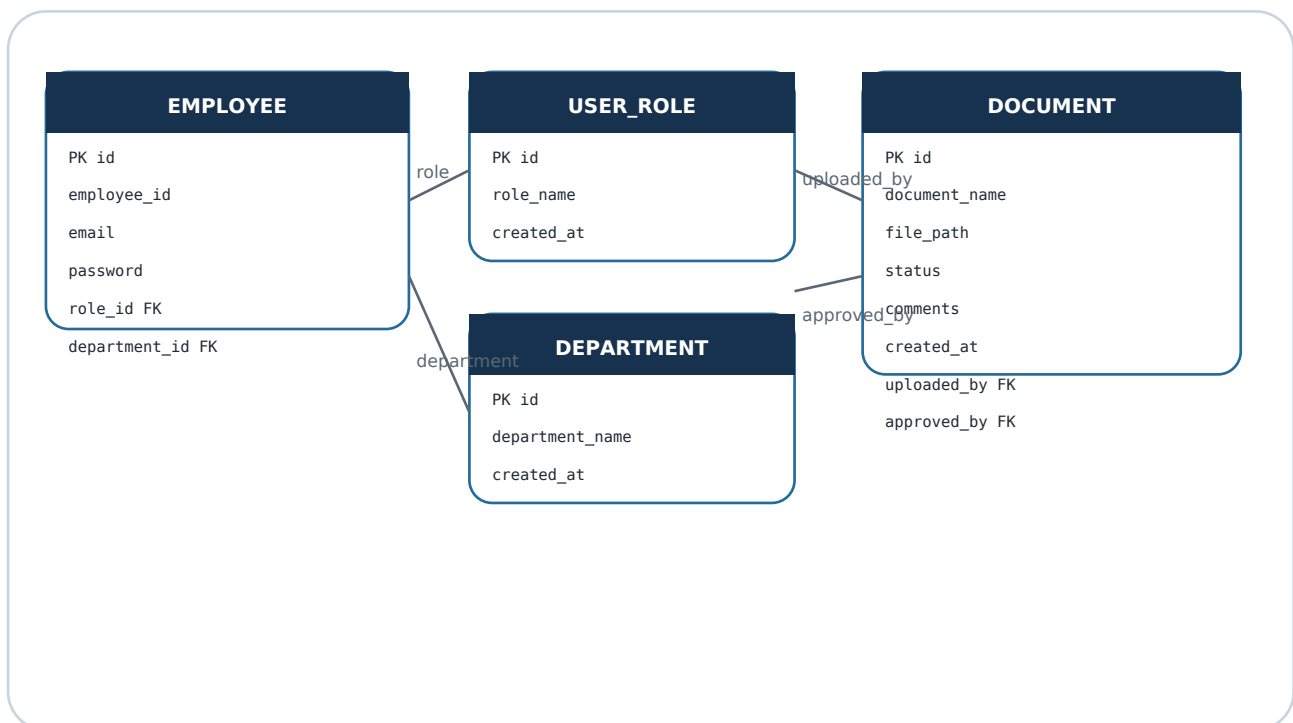
DATABASE

The application has relational data with clear relationships and constraints: employees belong to departments and roles, and documents reference employees. PostgreSQL provides strong relational integrity, transactions and mature SQL support.

35 Explain your employee-document relationship.

DATABASE

Employee stores identity and organization information. Document stores file metadata and references the employee who uploaded it and, when applicable, the approver. This avoids duplicating employee details inside every document row.



36 What are primary and foreign keys?

DATABASE

A primary key uniquely identifies a row. A foreign key references a key in another table and enforces a relationship. In this project, `document.uploaded_by` references `employee`, while `employee.role_id` references `user_role`.

37 What happens when JPA starts with `ddl-auto=none`?

DEBUGGING

Hibernate does not create or update the database schema. If the deployment database is empty, repository queries can fail because required tables do not exist. That was the reason a new Railway database produced a missing employee relation.

38 Why did `ddl-auto=update` solve the empty deployment schema?

DEPLOYMENT

It allowed Hibernate to create/update tables based on the mapped entities during deployment. It is convenient for a student/demo deployment, although production systems normally prefer controlled migrations such as Flyway or Liquibase.

39 What is a transaction?

DATABASE

A transaction groups database changes into a unit of work with atomicity and consistency guarantees. If an operation fails, the application can roll back changes rather than leaving partially updated state.

40 What is lazy vs eager loading?

DATABASE

Lazy loading defers loading related data until it is accessed; eager loading retrieves it earlier. Lazy loading can reduce unnecessary data retrieval but requires care around transaction boundaries and serialization.

41 How would you evolve the database for production?

FOLLOW-UP

Use versioned migrations, explicit indexes, audit tables, stronger status constraints, timestamps, unique constraints, backups and monitoring. I would avoid relying on automatic schema updates as the long-term migration strategy.

05 — PDF processing & QR verification

42 Why PDFBox?

PDF

PDFBox provides server-side PDF manipulation. It lets the application load an existing PDF, work with pages/content, add elements and save a new PDF artifact. This is more reliable than asking the browser to perform the authoritative approval modification.

43 Why ZXing?

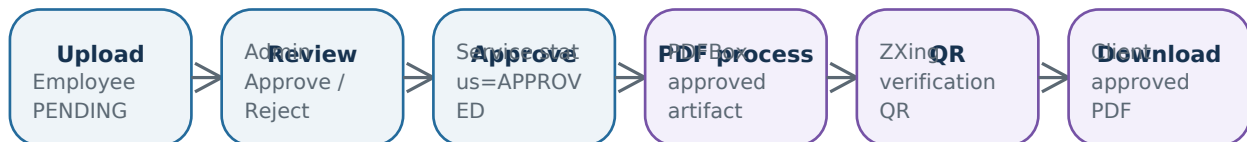
QR

ZXing provides QR code encoding. The service can convert a verification payload into a QR image and place that image into the approved PDF.

44 Explain the approval-to-QR workflow.

PDF/QR

Once an administrator approves a document, the backend changes the document state, processes the source PDF with PDFBox, generates a QR code using ZXing, places it into the approved artifact, and makes that artifact available for download.



45 Why generate the QR on the backend?

DESIGN

The approval decision is trusted backend state. Generating the QR on the server ensures the verification artifact is tied to the authoritative approval event rather than a client-controlled UI action.

46 Why not create a new PDF page for the QR?

PDF

It changes the document layout unnecessarily and can make the approved artifact less professional. A better implementation is to place the QR on the last existing page in an appropriate unused area while preserving existing signatures/content.

47 What can go wrong in PDF processing?

DEBUGGING

Malformed PDFs, encrypted PDFs, page-coordinate mistakes, content overlap, output-path problems, missing permissions, resource leaks and corrupted output are common risks. The service should validate inputs and close PDF resources reliably.

48 How would you improve QR verification?

FOLLOW-UP

I would create a dedicated verification endpoint that resolves the QR payload to server-side document state, shows approval metadata, and verifies the document identity rather than trusting arbitrary QR text.

06 — React, routing & API integration

49 How does React communicate with Spring Boot?

FRONTEND

Axios sends HTTP requests to the backend base URL. The base URL is supplied through `VITE_API_URL` so the same frontend code can target local or production environments. JSON responses are then used to update React state/UI.

50 Why Vite?

FRONTEND

Vite provides a fast development server and a modern production build pipeline for React. Environment variables prefixed with `VITE_` are exposed to the client bundle at build time.

51 What does React Router do?

FRONTEND

It maps client-side URLs to React components without requiring a full server-rendered page for each route. In production, the host must support SPA fallback so refreshing a route like `/login` does not produce a server 404.

52 Why did Vercel return 404 on refresh?

DEBUGGING

The browser was requesting a client-side route directly. Without an SPA rewrite, the hosting platform looked for a real file/path and returned 404. Adding a `vercel.json` rewrite to `index.html` allows React Router to handle the route.

53 What is the difference between 400, 401, 403 and 500?

WEB

400 means the request is invalid from the API's perspective; 401 means authentication is missing/invalid; 403 means the caller is authenticated but forbidden; 500 indicates an unexpected server-side failure. I use these codes together with logs and the Network tab to locate the failing layer.

54 How do you handle API errors on the frontend?

FRONTEND

The frontend should inspect the HTTP status, show a useful user-facing message, avoid exposing internal stack traces, and keep the API layer centralized so error handling is consistent.

55 Why should the API URL be environment-based?

DEPLOYMENT

The same frontend code must work locally and in production. Hard-coding `localhost` would break deployment; hard-coding production would make local development inconvenient. Build-time configuration solves this cleanly.

07 — Docker & deployment

56 Why Docker Compose?

DOCKER

It makes the local environment reproducible by defining frontend, backend and PostgreSQL as services. I can start the stack together instead of manually configuring each dependency.

57 What is the difference between a container and an image?

DOCKER

An image is a packaged template containing the application/runtime filesystem. A container is a running instance of an image with its own process and runtime state.

58 Explain your deployment architecture.

DEPLOYMENT

The React/Vite frontend is built and hosted by Vercel. The Spring Boot backend runs on Railway. PostgreSQL is also hosted on Railway. The frontend calls the backend over HTTPS using the production API URL.

59 What production environment variables matter?

DEPLOYMENT

The database URL, database username/password, JWT_SECRET and FRONTEND_URL are critical backend variables. The frontend needs VITE_API_URL at build time. These values should be injected by the hosting platform, not committed to source control.

60 What is the storage problem with Railway filesystem?

DEPLOYMENT

Application-local files may not survive restarts or redeployments depending on the hosting setup. Since approved PDFs are important artifacts, a production-grade design should use persistent storage or object storage rather than assuming the application container filesystem is durable.

61 How would you make the deployment more production-ready?

FOLLOW-UP

I would add database migrations, object storage, centralized logs/metrics, health checks, rate limiting, stronger secrets management, automated CI/CD tests, backup/restore procedures and better auditability.

08 — Debugging, scenarios & follow-ups

62 How would you debug a login 400 in production?

SCENARIO

First reproduce it and inspect the browser Network request. Then inspect backend logs for the corresponding timestamp. If the log shows a SQL relation/table error, verify database schema and connection. If authentication code fails, verify the employee row and password hash. I would change one layer at a time and retest.

63 How would you debug a CORS error?

SCENARIO

Confirm the browser's exact Origin header, compare it with FRONTEND_URL, ensure the backend CORS configuration allows that origin and HTTP method, and redeploy if the environment variable changed. I would not "fix" CORS by allowing every origin in production without understanding the security impact.

64 How would you debug "employee does not exist" or a missing relation?

SCENARIO

Check the SQL error first. If the relation itself is missing, the schema is not initialized or the application is connected to the wrong database. If the table exists but no row matches, inspect the actual employee data and query conditions.

65 What if the JWT is valid but an employee can approve a document?

SCENARIO

That indicates an authorization bug. Authentication succeeded, but the endpoint did not enforce the role/business rule correctly. I would inspect method security, endpoint rules and service-level checks, then add a regression test.

66 What if an approved PDF downloads but the QR is missing?

SCENARIO

I would verify that the approval service actually invoked QR generation, inspect the output filename/path, open the produced PDF directly, and verify the page/content coordinates. Then I would check whether the frontend downloaded the correct approved artifact rather than the original source file.

67 What if the QR appears on a blank extra page?

SCENARIO

The PDF code is probably creating a new page instead of appending content to the existing last page. I would change the implementation to select the final existing PDPAGE and append content in the correct mode, then retest with PDFs of different page counts.

68 What would you test before a demo?

TESTING

Login for each role, protected-route behavior, upload, pending visibility, approve, reject, approved download, QR presence, invalid token, unauthorized action, CORS, production API connectivity and a full end-to-end workflow from employee upload to admin approval.

69 What is one weakness of your current design?

HONESTY

The biggest production limitation is file persistence because application-local PDF storage is not a durable object-storage strategy. I would address it with persistent/object storage and make document metadata point to a durable artifact location.

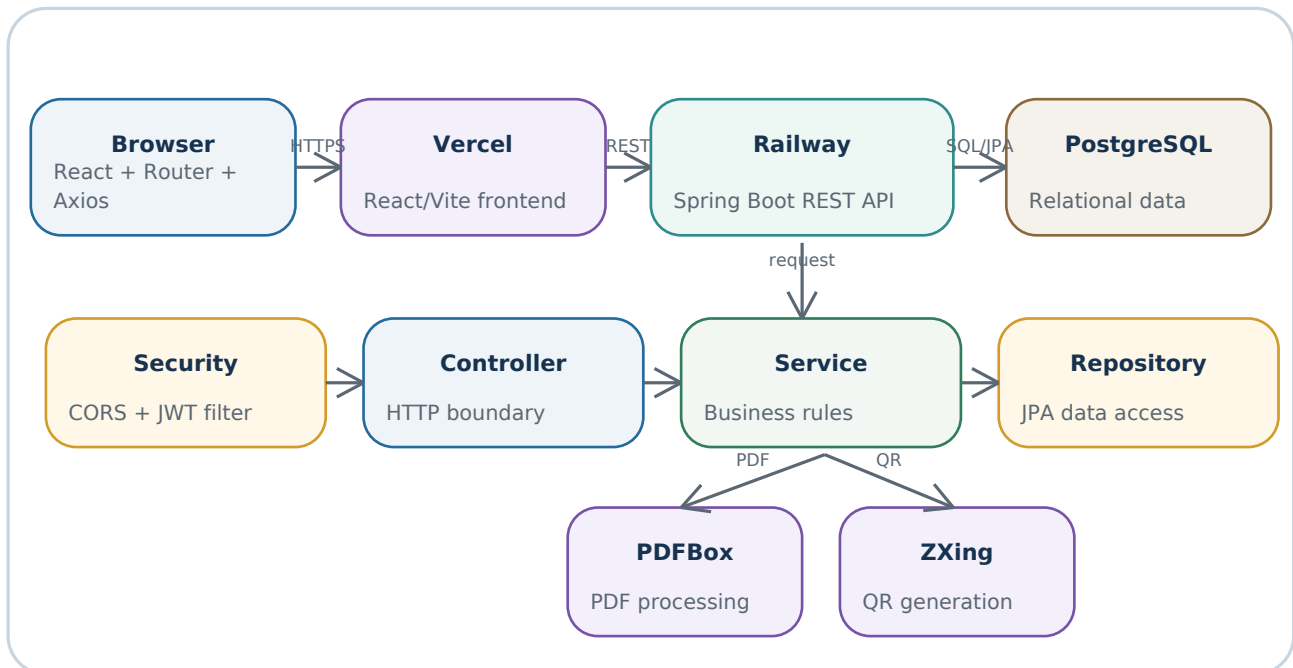
70 If you had two more weeks, what would you improve?

FOLLOW-UP

I would prioritize durable file storage, formal database migrations, a real QR verification endpoint, audit logging, stronger automated tests, centralized exception handling, API validation, CI/CD and better observability.

Final interview cheat sheet

Draw this first



Then explain one request

Browser → Axios → HTTPS → Security Filter → Controller → Service → Repository → PostgreSQL

Then explain approval

Admin approval → state transition → PDFBox → ZXing → approved PDF → download / verification

Then explain deployment

Vercel frontend → Railway backend → Railway PostgreSQL

Best interview habit

When asked “why?”, answer with a concrete project reason and a trade-off. Example: “I used a service layer so business rules were not coupled to HTTP, which makes them easier to test and reuse.”

One sentence to remember

“I can explain the system from the browser request all the way to the database and back, including where authentication, business rules, PDF processing and deployment boundaries sit.”